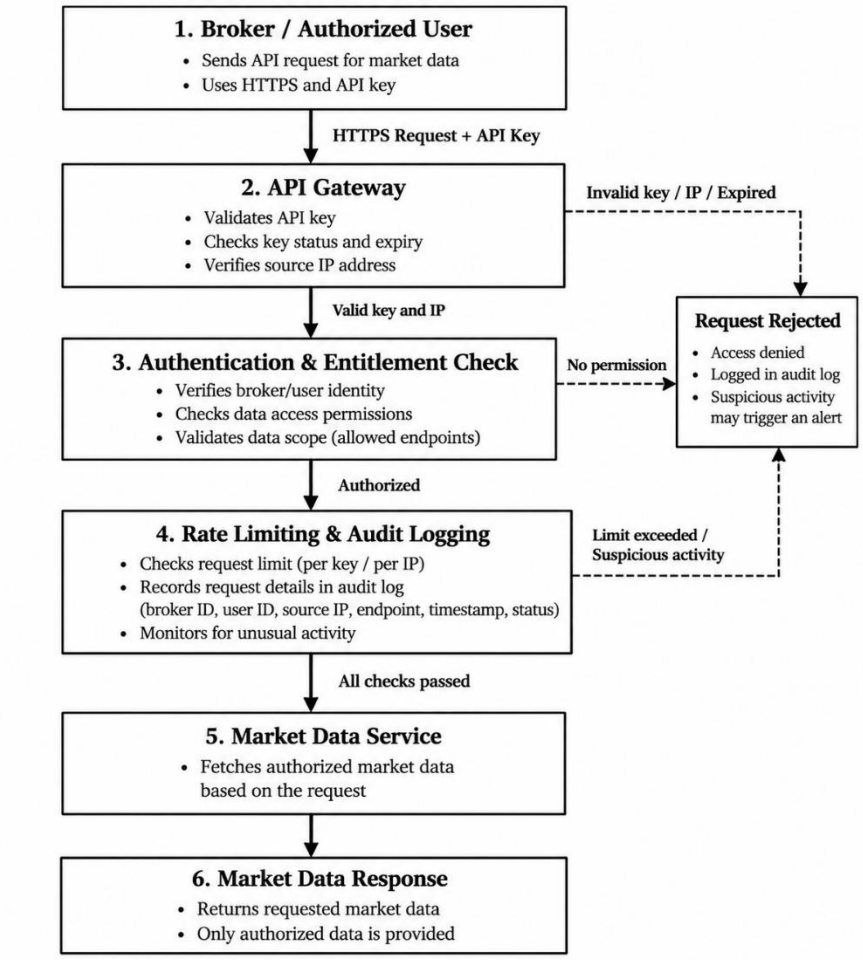
Assignment no 06

Architecture:



Database/Table Structure:

1.AccessControl

Field	Purpose
broker_id	Identifies the authorized broker
user_id	Identifies the authorized user
api_key_id	Identifies the API credential; store a secure hash of the key, not the raw secret
approved_source_ip	IP address permitted to use the credential
data_scope	Market-data types/endpoints the user may access
rate_limit	Maximum permitted requests in a defined time window
status	Active, suspended or revoked access state

expiry	Defines the date and time when the API credential expires.

2.AuditLog

Field	Purpose
audit_id	Unique audit event identifier
timestamp_utc	When the request occurred, in UTC
broker_id	Broker associated with the request
user_id	User associated with the request
api_key_id	Credential identifier used; never log the secret itself
source_ip	Source IP observed by the trusted gateway
endpoint_and_method	API path and HTTP method requested
outcome_status	Allowed/denied result and HTTP status code
request_id	Identifier used to trace the request across logs

Sample API Request

```
curl --request GET \
  'https://api.example.com/v1/market-data/quote?symbol=EXAMPLE' \
  --header 'X-API-Key: <YOUR_API_KEY>' \
  --header 'Accept: application/json' \
  --header 'X-Request-ID: demo-req-1001'
```

Expected successful response (example only):

```
{
  "request_id": "demo-req-1001",
  "symbol": "EXAMPLE",
  "last_price": 125.50,
  "currency": "INR",
  "timestamp_utc": "2026-10-11T08:30:00Z",
  "data_type": "delayed"
}
```

Sample Audit Record:

Field	Purpose
timestamp_utc	2026-10-11T08:30:01Z
broker_id	BRK-100
user_id	USR-204
api_key_id	KEY-778
source_ip	203.0.113.10 (documentation example IP)
method / endpoint	GET /v1/market-data/quote
data_scope	quotes
status_code / outcome	200 / ALLOWED
request_id	demo-req-1001
latency_ms	42

Security Controls: Each downstream broker must have its own approved API credentials. Sharing API keys with unauthorized brokers is prohibited, and suspicious usage will be monitored.

1. API Key and IP Restriction: Each authorized broker/user gets a unique API key. Access is allowed only from the approved source IP address.

2. Authentication and Authorization: Authentication verifies the broker/user identity, while authorization checks whether they have permission to access the requested market data.

3. Rate Limiting: The system limits the number of API requests to prevent excessive usage and API abuse.

4. Audit Logging: Every request is recorded with broker ID, user ID, source IP, endpoint, timestamp, and request status to support investigation.

5. Credential Revocation: Compromised or no-longer-required API keys can be disabled to prevent unauthorized access.

6. HTTPS/TLS Encryption: HTTPS protects API communication and credentials while data is transferred between the broker and server.

7. Security Monitoring: The system monitors repeated failures and unusual API usage. Suspicious activity can trigger alerts, and unauthorized requests are rejected.

Partner-Owned Downstream Data Warehouse

If the partner owns the downstream data warehouse, the agreement should define how the partner can store, use, retain, and share market data. Access should be limited to approved users and permitted purposes. API usage should be monitored through audit logs, and the partner must secure its warehouse and prevent unauthorized data sharing.